



Kali Tools GUI

ממשק גרפי ושכבת סוכני AI לכלי Kali Linux

שרת VPS · Kali

Purple Team AI

11 קטגוריות

74 כלים

מדריך הפעלה והדרכה מלא

מאת: **הראלי דודאי**

hareli26@gmail.com

תוכן עניינים

1. סקירה כללית
2. דרישות מקדימות ומה צריך להתקין
3. התקנה והפעלה
4. מצב "כלים" — שימוש ידני
5. מצב "עוזר AI" — שכבת הסוכנים
6. ארכיטקטורה
7. קטלוג הכלים והקטגוריות
8. פתרון תקלות
9. אבטחה ואתיקה

1. סקירה כללית

Kali Tools GUI היא מערכת גרפית (Web) המאחדת את כלי ה-Kali Linux. בייצור היא רצה על **שרת Kali Linux ייעודי (VPS)** מאחורי התחברות Google והרשאות תפקידים, ותומכת גם ב-WSL2 לפיתוח מקומי. המערכת מציעה מצבי עבודה:

- **מצב כלים** 🧰 — בחירת כלי מרשת כרטיסים, מילוי טופס יכולות עם תצוגת פקודה חיה, הרצה וצפייה בתוצאות במסך נפרד.
- **מצב עוזר AI** 🤖 — תיאור חופשי של הבדיקה הרצויה; שכבת סוכנים מתכננת, מריצה, מאמתת ומפיקה דוח.
- **מרכז בקרה** 📊 — מצב הסוכנים החי, מודיעין נצבר, ויומן פעילות.
- **תצוגת Obsidian** 📖 — גרף קשרים אינטראקטיבי בין הדוחות לאיומים (בתוך המערכת).
- **היסטוריה** 🕒 — כל הבדיקות לאורך זמן + השוואת שתי סריקות (מגמת אבטחה).
- **חומרי למידה** 📚 — Q&A חינוכי לכל איום (מהו, הגנה, זיהוי, תיקון, MITRE).
- **משתמשים + הרשאות (RBAC)** 👤 — (אדמין) ניהול חשבונות מורשים והקצאת תפקיד: admin / operator / viewer.
- **עורך Playbooks** 📝 — (אדמין) הוספת/עריכת חוקי סוכן בלי קוד.

סרגל ריצה גלובלי: בכל מסך, כל עוד משימה פעילה, מופיע סרגל תחתון שמראה בזמן אמת מה הסוכן עושה (הכלי הנוכחי + התקדמות) ומאפשר חזרה למשימה בלחיצה — כך שלעולם לא "מאבדים" ריצה. המשימות רצות בשרת ולא נעצרות בניווט.

השרת רץ על שרת ה-Kali בספריית פייתון סטנדרטית בלבד (אפס תלויות), ומזהה אוטומטית אילו כלים מותקנים. אופציונלית, מודל **LLM מקומי (Ollama)** משדרג את ניסוח הדוחות.

2. השרתים ומערכות הפעלה

המערכת פרוסה על **שני שרתים נפרדים**, לכל אחד תפקיד ומערכת הפעלה משלו. ההפרדה מכוונת: מלכודת הדבש היא שרת שמזמינים לפרוץ אליו, ולכן אסור שתחלוק מכונה עם הפרודקשן.

שרת	מערכת הפעלה	תפקיד	כתובת
 פרודקשן	Kali Linux (VPS)	מריץ את האפליקציה, שכבת הסוכנים, החיישן ושרת ה-MCP	kali.dudaei.com 72.62.150.169
 מלכודות	Ubuntu 24.04 (VPS) (מוקרב נפרד)	מריץ את מלכודות הדבש בלבד (ווב / MySQL / SSH)	web.dudaei.com 187.124.189.97

דרישת התקנה יחידה: python3 (+3.9) — הליבה כתובה בספריית פייתון הסטנדרטית בלבד, **אפס תלויות**. יוצא דופן יחיד: מלכודת ה-SSH (על שרת המלכודות) משתמשת ב-paramiko, כי SSH מצפין ב-AES שאין בספרייה הסטנדרטית — הפרודקשן נשאר ללא תלויות.

על שרת ה-Kali, ההתקנה הבסיסית של הכלים מינימלית; אין חובה להתקין הכול מראש — המערכת **מזהה אוטומטית** אילו כלים מותקנים ומציעה כפתור התקנה לכל כלי חסר. לסט מלא:

```
sudo apt update && sudo apt install -y kali-linux-default # או kali-linux-everything
```

פיתוח מקומי (אופציונלי): Windows 10/11 עם **WSL2 + Kali** — לפיתוח בלבד, לא לייצור (-- wsl install -d kali-linux). דפדפן מודרני (Chrome/Edge/Firefox) לצד הלקוח.

3. התקנה והפעלה

3א. פריסה בייצור — שרת (VPS) Kali

בייצור, מתקין יחיד מקים את הכל על שרת Kali נקי: כלי Kali, האפליקציה, מסד הנתונים, שרת ה-MCP, HTTPS (Caddy + oauth2-proxy עם התחברות Google) ו-firewall:

```
git clone https://github.com/<user>/kali-tools-gui.git /opt/kali-gui
cd /opt/kali-gui
cp deploy/deploy.env.example deploy/deploy.env # DOMAIN + Google client id/secret
bash deploy/install-vps.sh
```

ניהול השירות על השרת:

```
systemctl status kali-gui # מצב
systemctl restart kali-gui # הפעלה מחדש
journalctl -u kali-gui -n 50 # לוגים
```

3ב. פריסת מלכודות הדבש — שרת Ubuntu מוקרב

מלכודות הדבש רצות על השרת המוקרב הנפרד (Ubuntu 24.04) — לעולם לא על הפרודקשן. הסקריפטים מסרבים לרוץ אם הם מזהים שהם על שרת הפרודקשן:

```
# על שרת המלכודות (187.124.189.97):
sudo HP_DOMAIN=web.dudaei.com HP_PROD_IP=72.62.150.169 ./deploy/install-honeypot.sh
# ווב
sudo HP_PROD_IP=72.62.150.169 ./deploy/add-sql-honeypot.sh # MySQL
sudo HP_PROD_IP=72.62.150.169 ./deploy/add-ssh-honeypot.sh # SSH

# על הפרודקשן — רישום + משיכה אוטומטית כל 60 שניות:
python3 sensor.py --add web http://187.124.189.97:8081 <token>
```

כל מלכודת חושפת פורט ציבורי (הפיתיון) וקולקטור מוגן בטוקן ומוגבל ב-firewall ל-IP הפרודקשן. פירוט מלא: [honeypot/README.md](#).

3ג. פיתוח מקומי — WSL2 (אופציונלי)

המערכת רצה כ-root כדי שכל הכלים יעבדו. לפיתוח מקומי בלבד, תחת Kali-WSL על Windows:

```
wsl -d kali-linux -u root -- python3 /path/to/kali-gui/server.py
# וואז בדפדפן: http://localhost:8777
```

4. מצב "כלים" – שימוש ידני

שלב א – בחירת כלי

חפש בתיבת החיפוש או סנן לפי קטגוריה. כרטיס ירוק = מותקן, אפור = לא מותקן (לחיצה מציעה התקנה).

שלב ב – טופס והרצה

בראש המסך מופיע כרטיס **i על הכלי – מה זה ומה אפשר לעשות** המסביר את הכלי ושימושיו. מלא את השדות; **הפקודה המלאה מתעדכנת בזמן אמת**. שדות חובה מסומנים ב-*. לחץ ► הרץ.

שלב ג – תוצאות

מסך נפרד עם פלט חי, סטטוס וכפתורי עצור / העתק / הורד / הרץ שוב.

5. מצב "עוזר AI" – שכבת הסוכנים

Intent → Planner → [Approve] → Executor → Verifier → Reporter → Report

Planner (מתכנן)

מקבל כוונה בשפה חופשית + מטרה, מזהה את ה-playbook המתאים ובונה תוכנית שלבים עם פקודות מוכנות והצעות.

Executor (מבצע)

מריץ כל שלב ברצף לאחר אישורך.

Verifier (מאמת)

מנתח פלט + קוד יציאה ונותן verdict:  תקין •  ממצאים •  אזהרה •  נכשל, כולל חילוך ממצאים.

Reporter (מדווח)

מפיק דוח מלא: סיכום מנהלים, ממצאים עיקריים ופירוט שלבים – ניתן להעתקה/הורדה.

Playbooks זמינים: DNS • תת-דומיינים • סריקת פורטים • בדיקת חדירות • Active • SMB/Windows • Directory • API • מיפוי רשת • OSINT • WordPress • SQL Injection • SSL/TLS • חיפוש אקספלויטים (Exploit-DB) • פורנזיקה/סטגנוגרפיה.

5א. תצוגת Obsidian (גרף קשרים)

טאב  **Obsidian** מציג את כל הבדיקות כגרף אינטראקטיבי — בדיוק כמו ה-Graph View של Obsidian, בתוך המערכת:

- צומת מרכזי • דוחות • איורים צבועים לפי חומרה, מחוברים בקווים.
-  גרור צומת • גלגל להתקרב • לחיצה פותחת את הפתק המלא בצד • חיפוש צמתים.
- הגרף נבנה אוטומטית מכל בדיקה. כפתור "ייצא כספת" שומר גם קבצי Markdown לפתיחה ב-Obsidian הדסקטופ.

5ב. ניהול משתמשים (אדמין)

בפריסת הענן, הכניסה היא בהתחברות **Google** ורק למי שהוגדר. טאב  **משתמשים** מופיע רק לאדמין ומאפשר לנהל את זה מהמשק:

- הקלד כתובת Gmail → **הוסף**. המשתמש יוכל להיכנס תוך שניות (ללא restart).
-  **הסר** חוסם משתמש מיידית. אי אפשר להסיר את האדמין עצמו (מניעת נעילה).
- כל הוספה/הסרה נרשמת ביומן הביקורת. הפעולות מוגנות בצד השרת (אדמין בלבד).

5ג. מסכים נוספים

היסטוריה והשוואת סריקות

רשימת כל הבדיקות לאורך זמן. בחירת שתי סריקות Purple של אותה מטרה מציגה **מגמת אבטחה**: אילו איורים **נפתרו**, אילו **חדשים**, ואילו **עדיין פתוחים**, עם פסק שיפור/הרעה/יציב.

חומרי למידה

דף לימוד: מה המערכת למדה (מונה הופעות לכל איום) ו-Q&A לכל סוג ממצא — מהו, איך מתגוננים, איך מזהים (כולל חוקי Sigma/Suricata), האם יש תיקון אוטומטי, ושיוך MITRE ATT&CK.

עורך Playbooks (אדמין)

הוספה/עריכה של חוקי הסוכן ישירות מהמשק — **מבוסס-דאטה** עם מציני מקום בטוחים (`{target}`), `{host}`, `{url}`, `{domain}`, ללא הרצת קוד. הסוכן משתמש בהם אוטומטית לפי מילות המפתח.

גלקסיה 3D (Obsidian)

תצוגת כספת חלופית: שדה כוכבים תלת-מימדי שבו כל כוכב הוא נתון (דוח/איום). גרירה לסיבוב, גלגלת לטיסה, גרירת כוכב להזזה, ולחיצה לפתיחת הפתק — קנבס טהור, אפס ספריות חיצוניות.

6. ארכיטקטורה

```
דפדפן —HTTPS→ Caddy → oauth2-proxy (Google + RBAC)
                        |
                        ▼
server.py (Python stdlib, root, על שרת Kali)
├─ tools.json   קטלוג 74 כלים
├─ agents.py    Planner / Verifier / Reporter (+ LLM (אופציונלי
├─ bluered.py  Broker / Blue / Learning / Fixer
├─ db.py        SQLite (ידע, פעילות, ביקורת, דוחות, תפקידים)
└─ subprocess → (argv, ללא shell) אמיתיים Kali כלים
```

עקרון אבטחה מרכזי: הפקודות נבנות בצד השרת כמערך `argv` ללא `shell` — הגנה מהזרקת פקודות.

7. קטלוג הכלים והקטגוריות

קטגוריה	כלים לדוגמה
Recon / איסוף מידע	whois, whatweb, theHarvester, subfinder, dmitry, sherlock
DNS	dig, dnsenum, dnsrecon, fierce
Network / רשת	nmap, masscan, netdiscover, arp-scan, hping3, fping, tcpdump
Web	nikto, gobuster, ffuf, wpscan, sqlmap, nuclei, httpx, wfuzz
SMB / Enumeration	enum4linux-ng, smbclient, crackmapexec, rpcclient, snmpwalk
Passwords	hydra, medusa, john, hashcat, crunch, cewl, hashid
SSL / TLS	ssllscan, sslyze
Exploitation	searchsploit, msfvenom
Forensics	binwalk, foremost, exiftool, steghide, strings
Wireless	aircrack-ng
Utilities	ping, curl, traceroute, macchanger

8. פתרון תקלות

פתרון	תקלה
ודא שהשרת רץ ושפורט 8777 פנוי	הדף לא נטען
לחץ התקן, או <code>apt install <package></code>	כלי "לא מותקן"
ודא הרצה עם <code>-u root</code>	"דרוש root"
בצע תיקון DNS (סעיף 3)	דומיין לא נפתר
VPS/VM ללא כרטיס אלחוטי במצב monitor — צפוי; רק aircrack-ng offline נתמך	כלי אלחוטי לא עובד

9. אבטחה ואתיקה

אזהרה: הרץ כלים אך ורק על מטרות שיש לך הרשאה חוקית מפורשת לבדוק. שימוש בכלי פנטסט כנגד מערכות ללא רשות עלול להיות עבירה פלילית.

- המערכת מקומית בלבד; הפקודות נבנות בצד השרת ללא shell.
- שכבת ה-AI מציעה תוכנית — אתה מאשר לפני כל הרצה. שמור על שלב אישור זה.
- הסיסמה בשדה ההתקנה (במצב non-root) משמשת מקומית בלבד ואינה נשמרת.

— סוף המדריך · הראלי דודאי · 2026 —